

OWASP TOP-10 AGENTIC AI			
Risiko-Kategorien wie sie im Audit-Trail (Spalte OWASP) und Workflow-Detail erscheinen. OWASP-Referenz			
ID	NAME	KEY	BESCHREIBUNG
A01	Unrestricted Agency	unrestricted_agency	Agent führt Aktionen ohne Berechtigungs-Schranken aus — z.B. Self-Repair, Force-Push, Schranken-Übergehen.
A02	Uncontrolled Agentic Behavior	uncontrolled_behavior	Agent zeigt unkontrolliertes Verhalten ohne Aufsicht — z.B. Approval-Bypass, Workflow-Entgleisung, Konfig-Änderung.
A03	Inadequate Sandboxing	inadequate_sandboxing	Agent kann Sandbox/Worktree-Schutz unterlaufen — z.B. Quality-Gate-Bypass, Step-Bypass, Self-Check-Failure.
A04	Broken Trust Boundaries	broken_trust_boundaries	Agent verletzt Slice-/Modul-/System-Grenzen — z.B. Cross-Slice-Import, destruktive Merges, Branch-Stale.
A05	Identity & Access Abuse	identity_access_abuse	Agent missbraucht Identität oder Zugriffsrechte — z.B. unbefugte Issue-/Label-/Comment-Operations, Env-Exposure.
A06	Unmonitored Agent Activities	unmonitored_activities	Agent-Aktivitäten ohne Audit-Trail oder Logging — z.B. LLM-Calls, System-Events, Health-Checks ohne Sichtbarkeit.
A07	Unsafe Tool/API Integration	unsafe_tool_integration	Agent ruft Tools/APIs unsicher auf — z.B. Patch-Apply, Changelog-Update, PR-Exists ohne Validation.
A08	Excessive Autonomy	excessive_autonomy	Agent agiert autonomer als nötig — z.B. eigenmächtiges Healing, Auto-Implementation, Self-Repair.
A09	Inadequate Feedback Loops	inadequate_feedback_loops	Eval-/Test-/AC-Verifikations-Schleifen unzureichend — Score-Aussagekraft kompromittiert, Test-Failures unbemerkt.
A10	Opaque Agent Reasoning	opaque_reasoning	Agent-Entscheidungen sind nicht nachvollziehbar — Routing/Context-Auswahl ohne Begründung, intransparente Plan-Generierung.

EU AI ACT — RELEVANTE ARTIKEL	
Artikel-Nummern aus VO (EU) 2024/1689 wie sie im Audit-Trail (Spalte AI Act) erscheinen.	
ARTIKEL	BESCHREIBUNG
Art. 12	Aufzeichnungspflicht (Logging) für High-Risk AI Systems — automatische Protokollierung relevanter Ereignisse über die gesamte Lebensdauer des Systems.
Art. 13	Transparenz und Information für Nutzer — Anbieter müssen betroffene Nutzer eindeutig informieren, wenn ein AI-System eingesetzt wird.
Art. 14	Menschliche Aufsicht (Human Oversight) — High-Risk AI Systems müssen von natürlichen Personen wirksam beaufsichtigt werden können (Stop-/Override-Mechanismen).
Art. 15	Genauigkeit, Robustheit und Cybersicherheit — Resilienz gegen Fehler, Inkonsistenzen, Adversarial-Inputs.
Art. 50	Transparenzpflichten für AI-generierte Inhalte — Output muss als künstlich erzeugt gekennzeichnet werden (Watermarking, AI-Attribution).